Risk Register

Organization: COOKIE-BANNER.CA **Contact:** security@cookie-banner.ca **Document Owner:** Founder (sole operator)
Effective Date: 2026-03-28 **Next Review Date:** 2026-06-28 **Classification:** Internal – Confidential

---

1. Purpose

This Risk Register identifies, assesses, and tracks information security and operational risks facing COOKIE-BANNER.CA, a cloud-native cookie consent management platform (CMP). It serves as the central record for risk management decisions and supports compliance obligations under GDPR, PIPEDA, Quebec Law 25, and PECR.

As a solo-founder, fully virtual organization with no physical infrastructure, the risk profile is shaped primarily by dependency on third-party cloud providers, the sensitivity of consent and customer data processed, and the concentration of operational knowledge in a single individual.

2. Methodology

Risks are assessed using a qualitative likelihood-times-impact methodology:

Risk Score = Likelihood x Impact

Likelihood Scale

Score	Rating	Description
1	Rare	May occur only in exceptional circumstances (less than once per 5 years)
2	Unlikely	Could occur but not expected (once per 2-5 years)
3	Possible	Might occur at some point (once per 1-2 years)
4	Likely	Will probably occur in most circumstances (once or more per year)
5	Almost Certain	Expected to occur frequently (multiple times per year)

Impact Scale

Score	Rating	Description
1	Negligible	No measurable effect on operations or data; resolved within normal workflow
2	Minor	Minor inconvenience; limited data affected; resolved within hours
3	Moderate	Noticeable service degradation; partial data exposure; regulatory notification may be required
4	Major	Significant service outage; confirmed data breach; regulatory investigation likely
5	Severe	Complete service loss; large-scale data breach; material legal/financial consequences

Risk Rating Thresholds

Score Range	Rating	Response
1 – 5	**Low**	Accept and monitor; review at next scheduled assessment

Score Range	Rating	Response
6 – 12	**Medium**	Mitigate with defined controls; track actively
13 – 19	**High**	Prioritize for treatment; escalate to founder review
20 – 25	**Critical**	Immediate action required; implement controls before proceeding

Review Schedule

This register is reviewed **quarterly** by the founder. Ad-hoc reviews are triggered by material changes to infrastructure, a security incident, or a significant regulatory development.

---

3. Risk Register

ID	Risk Description	Category	Likelihood	Impact	Score	Current Mitigations	Residual Risk	Owner	Status
R-001	**Unauthorized access to consent data** – An attacker gains access to the Supabase PostgreSQL database containing consent records, exposing user consent preferences and associated metadata.	Data Security	2	4	**8 (Medium)**	Supabase row-level security (RLS) policies enforced on all tables; database credentials stored as encrypted Vercel environment variables; API routes require authenticated sessions via NextAuth.js; no direct database exposure to the public internet; Supabase enforces TLS in transit and encryption at rest.	Medium – RLS misconfiguration or leaked credentials remain possible vectors. No independent penetration testing performed to date.	Founder	Active
R-002	**Supabase outage or data loss** – Supabase experiences a regional outage or data corruption event, rendering the platform unable to read/write consent records or serve the dashboard.	Infrastructure	3	4	**12 (Medium)**	Supabase provides automated daily backups with point-in-time recovery (PITR); backup restoration procedures documented in `policies/backup-restore-test-log.md`; ETag/304 caching strategy reduces read dependency during short outages; banner widget serves cached configuration from CDN edge.	Medium – Recovery time depends entirely on Supabase; no self-hosted replica or multi-region failover. RPO limited to Supabase backup frequency.	Founder	Active
R-003	**Vercel outage or service disruption** – Vercel experiences a	Infrastructure	3	3	**9 (Medium)**	Vercel Edge Network provides multi-region redundancy; static assets and banner scripts served from	Medium – Full Vercel outage would render the dashboard and API inaccessible. Banner widget may continue to	Founder	Active

ID	Risk Description	Category	Likelihood	Impact	Score	Current Mitigations	Residual Risk	Owner	Status
	platform-wide or regional outage, taking the dashboard, API routes, and banner delivery offline.					CDN with aggressive caching; serverless functions auto-scale; Vercel status page monitored.	function from CDN cache for existing visitors.		
R-004	**Stripe integration failure** – Stripe API outage or webhook delivery failure prevents subscription management, payment processing, or plan enforcement.	Financial	2	3	**6 (Medium)**	Stripe webhook endpoint includes retry logic and idempotency keys; subscription status cached in local database to avoid real-time Stripe dependency for access control; Stripe's own SLA and redundancy; payment failure notifications configured.	Low – Temporary Stripe outage would not lock out existing subscribers. New signups and plan changes would be delayed but not lost due to Stripe's retry mechanism.	Founder	Active
R-005	**Supply chain attack via compromised npm dependency** – A malicious package update is introduced through a direct or transitive npm dependency, potentially exfiltrating data or injecting code into the banner widget served to end users.	Supply Chain	3	5	**15 (High)**	Dependabot alerts enabled on GitHub repository; `package-lock.json` pinned and committed; dependencies reviewed before major upgrades; Next.js and core packages sourced from well-maintained, widely-audited projects; banner widget output is a controlled, minimal JavaScript payload.	High – No automated Software Composition Analysis (SCA) tool in CI pipeline; no Subresource Integrity (SRI) hashes on delivered scripts; transitive dependency tree is large and not fully auditable by a solo operator.	Founder	Active
R-006	**Key person risk (solo founder)** – The sole operator becomes unavailable due to illness, injury, or other personal circumstances, leaving the platform without anyone to	Operational	3	5	**15 (High)**	Incident response plan documented in `policies/incident-response-plan.md`; all credentials stored in a password manager with emergency access procedure; infrastructure is fully managed (Vercel, Supabase, Stripe) requiring minimal active intervention; platform can operate	High – No backup operator, on-call rotation, or succession plan. Extended unavailability would leave the business unable to respond to security incidents or regulatory requests within required timeframes.	Founder	Active

ID	Risk Description	Category	Likelihood	Impact	Score	Current Mitigations	Residual Risk	Owner	Status
	respond to incidents, process support requests, or maintain infrastructure.					unattended for extended periods.			
R-007	**DDoS attack on banner widget endpoint** – A distributed denial-of-service attack targets the banner configuration API or widget script endpoint, degrading service for all customers' websites.	Security	3	3	**9 (Medium)**	Vercel Edge Network provides built-in DDoS protection and automatic scaling; banner configuration served from CDN cache with appropriate TTLs; API rate limiting applied to authenticated endpoints; widget is a lightweight static asset with minimal server-side computation per request.	Medium – Sustained volumetric attack could exhaust Vercel's included limits or incur unexpected costs. No dedicated WAF or advanced DDoS mitigation service in place.	Founder	Active
R-008	**Regulatory non-compliance due to evolving privacy laws** – Changes to GDPR, PIPEDA, Quebec Law 25, PECR, or the introduction of new privacy regulations (e.g., US state laws, ePrivacy Regulation) render the platform non-compliant or require features not yet implemented.	Compliance	4	4	**16 (High)**	Active monitoring of regulatory developments in target jurisdictions; platform architecture designed for configurable consent categories; consent logging feature supports DSAR proof-of-consent requirements; privacy policies and data processing documentation maintained.	High – Solo operator has limited bandwidth to track all jurisdictions simultaneously. Implementing compliance changes for new regulations requires development time with no dedicated legal counsel on retainer.	Founder	Active
R-009	**Loss of access to cloud accounts** – Founder loses access to critical accounts (Vercel, Supabase,	Operational	2	5	**10 (Medium)**	MFA enabled on all critical accounts; credentials stored in a password manager; MFA recovery codes stored separately in secure offline backup; account recovery email is a	Medium – Single person holds all account access. Loss of the password manager master credential or MFA device would require provider-level account recovery, which may take days.	Founder	Active

ID	Risk Description	Category	Likelihood	Impact	Score	Current Mitigations	Residual Risk	Owner	Status
	Stripe, GitHub, domain registrar, DNS provider) due to compromised credentials, lost MFA device, or account lockout.					domain-controlled address.			
R-010	**Third-party provider security incident** – A security breach at Supabase, Vercel, Stripe, or GitHub exposes COOKIE-BANNER.CA customer data, source code, or API keys.	Third Party	2	4	**8 (Medium)**	All providers selected are SOC 2 Type II compliant; minimal data shared with each provider (principle of least privilege); Stripe handles all payment card data (PCI DSS compliant) so no card data touches COOKIE-BANNER.CA infrastructure; API keys rotatable; GitHub branch protection and audit logging enabled.	Medium – No contractual right to audit providers; limited visibility into their internal security posture. A provider breach could require emergency credential rotation and customer notification.	Founder	Active
R-011	**Insider threat from future employees or contractors** – A future employee, contractor, or collaborator with access to source code, databases, or cloud accounts intentionally or accidentally causes data loss, exfiltration, or service disruption.	Personnel	1	4	**4 (Low)**	Currently a solo operation with no employees or contractors; no shared access to production systems; GitHub repository is private; all environment variables managed through Vercel's encrypted secrets (not committed to source).	Low – Risk is theoretical at present. No access controls, onboarding/offboarding procedures, or least-privilege access policies have been formalized for future hires. This risk will require re-assessment before onboarding any personnel.	Founder	Monitor
R-012	**Client-side script injection via banner widget** – An attacker exploits a vulnerability in the banner widget	Application Security	2	5	**10 (Medium)**	Banner widget is a controlled, minimal JavaScript payload generated server-side; output is sanitized and does not include user-supplied content in executable contexts; Content Security	Medium – Widget runs on third-party domains with broad DOM access by necessity. A successful injection would have severe blast radius across all customer sites. No formal code audit or	Founder	Active

ID	Risk Description	Category	Likelihood	Impact	Score	Current Mitigations	Residual Risk	Owner	Status
	JavaScript to inject malicious code that executes on customer websites, potentially stealing end-user data or defacing sites.					Policy headers recommended to customers; no dynamic code execution or unsafe string-to-code patterns used in widget code.	bug bounty program exists.		
R-013	**Domain or DNS compromise** – An attacker gains control of the cookie-banner.ca domain through registrar account compromise, DNS hijacking, or expired domain, redirecting traffic or intercepting API requests.	Infrastructure	1	5	**5 (Low)**	Domain registrar account protected with MFA; domain locked (transfer lock enabled); DNSSEC enabled where supported by registrar; auto-renewal configured with valid payment method; DNS managed through a reputable provider.	Low – Domain compromise would be catastrophic but probability is low with current controls. No domain monitoring or certificate transparency log alerting in place.	Founder	Monitor
R-014	**Stale dependencies with known vulnerabilities** – npm packages in the project accumulate known CVEs over time due to infrequent updates, creating exploitable attack surface in the application or banner widget.	Supply Chain	4	3	**12 (Medium)**	Dependabot alerts enabled on GitHub; `npm audit` run periodically; Next.js framework updated regularly as part of feature development; Vercel build process surfaces dependency warnings.	Medium – No automated CI gate that blocks deployment on critical CVEs. Updates are manual and may be deferred during feature development sprints. Transitive vulnerabilities may go unnoticed.	Founder	Active

---

4. Risk Heat Map Summary

	Negligible (1)	Minor (2)	Moderate (3)	Major (4)	Severe (5)
Almost Certain (5)					
Likely (4)				R-008	
Possible (3)			R-003, R-007	R-002	R-005, R-006

	Negligible (1)	Minor (2)	Moderate (3)	Major (4)	Severe (5)
Unlikely (2)			R-004	R-001, R-010	R-009, R-012
Rare (1)				R-011	R-013

---

5. Risk Acceptance Statement

I, as the sole founder and operator of COOKIE-BANNER.CA, have reviewed all risks identified in this register. I understand the residual risk levels and accept them given the current stage of the business, available resources, and mitigations in place.

I commit to:

- Reviewing this register quarterly (next review: **2026-06-28**)
- Re-assessing risks whenever material changes occur to infrastructure, staffing, or regulatory requirements
- Prioritizing treatment of any risk that escalates to **High** or **Critical** rating
- Maintaining documentation of risk treatment decisions

Risks rated **High** (R-005, R-006, R-008) are accepted with the acknowledgment that additional mitigations should be evaluated as the business scales, including: engaging a part-time security consultant, implementing automated SCA tooling in CI, formalizing a succession plan, and retaining privacy legal counsel.

Accepted by:

Name: _____

Role: Founder, COOKIE-BANNER.CA

Signature: _____

Date: _____

---

6. Document Control

Version	Date	Author	Changes
1.0	2026-03-28	Founder	Initial risk register created

This document is reviewed quarterly. For questions or to report a new risk, contact security@cookie-banner.ca.